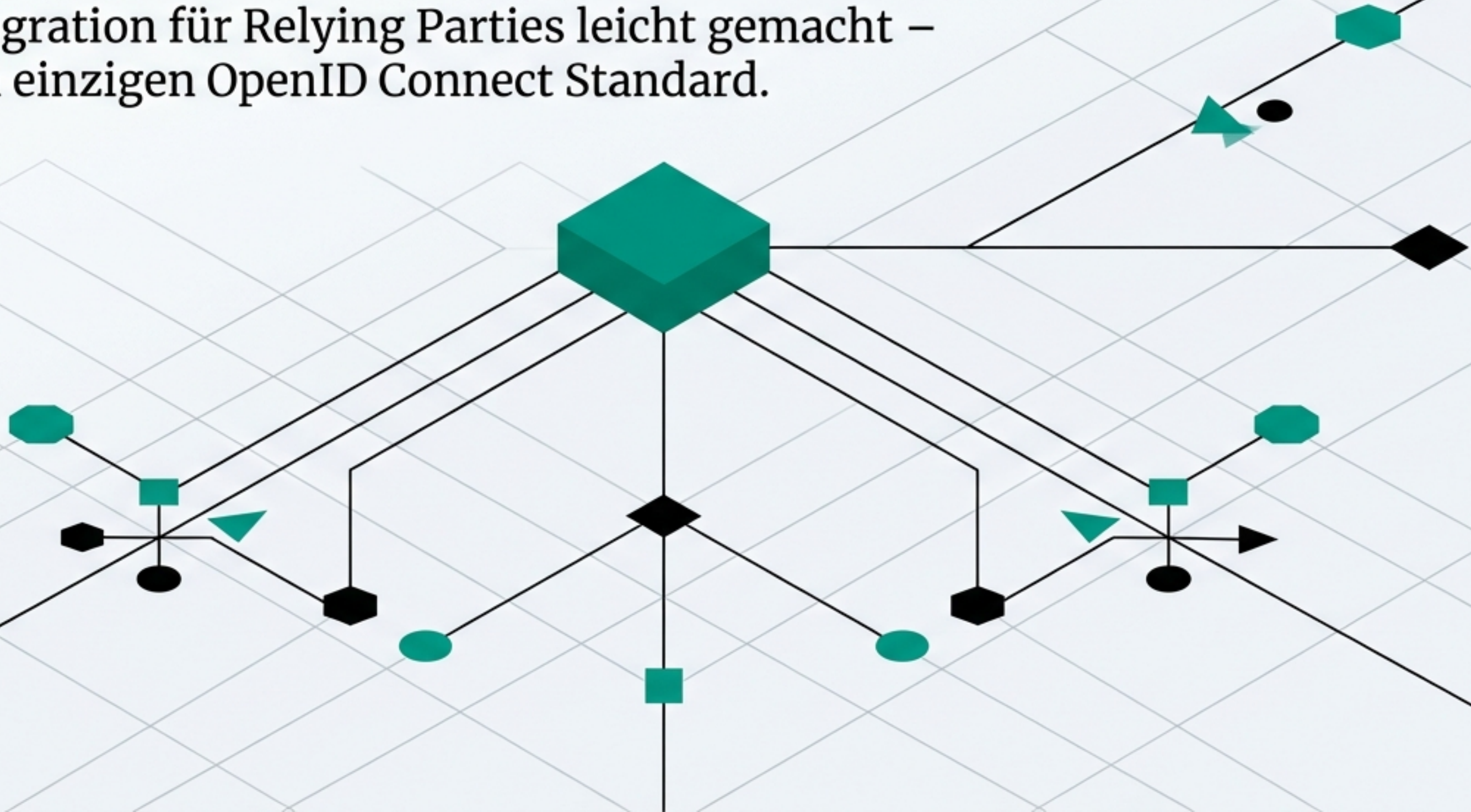


Mobile ID Passkeys: Die Zukunft der passwortlosen Authentisierung

FIDO2-Integration für Relying Parties leicht gemacht – über einen einzigen OpenID Connect Standard.



Warum Passkeys? Warum jetzt?



7'000

**Passwort-Angriffe
pro Sekunde**
(Microsoft 2025)

47% der Konsumenten
brechen Käufe ab, wenn sie
ihr Passwort vergessen.



>99%

Phishing-Resistenz

FIDO2-basierte Authentisierung
eliminiert die Schwächen von
herkömmlichem SMS-OTP.

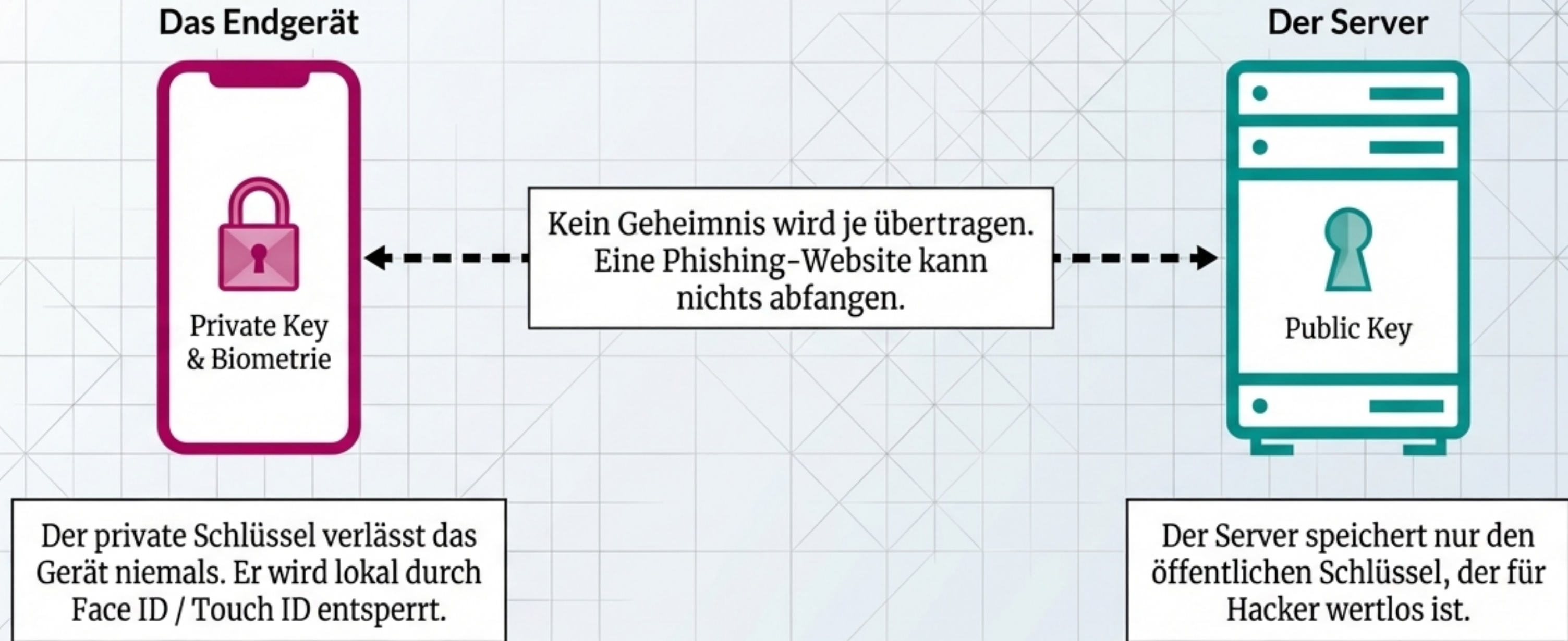


30% & 70%

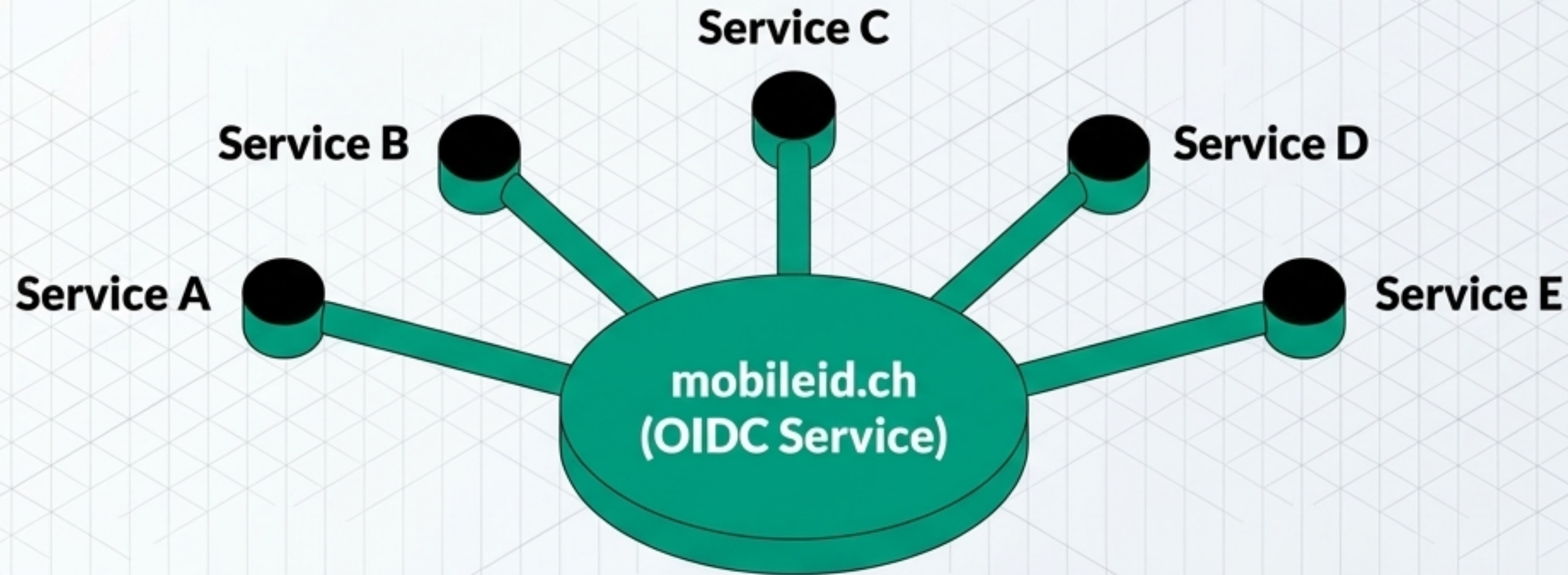
**Schnellere Logins &
weniger Support-Anfragen**

Login in unter 3 Sekunden
via Face ID oder Touch ID.

Passkeys einfach erklärt: Asymmetrische Kryptografie



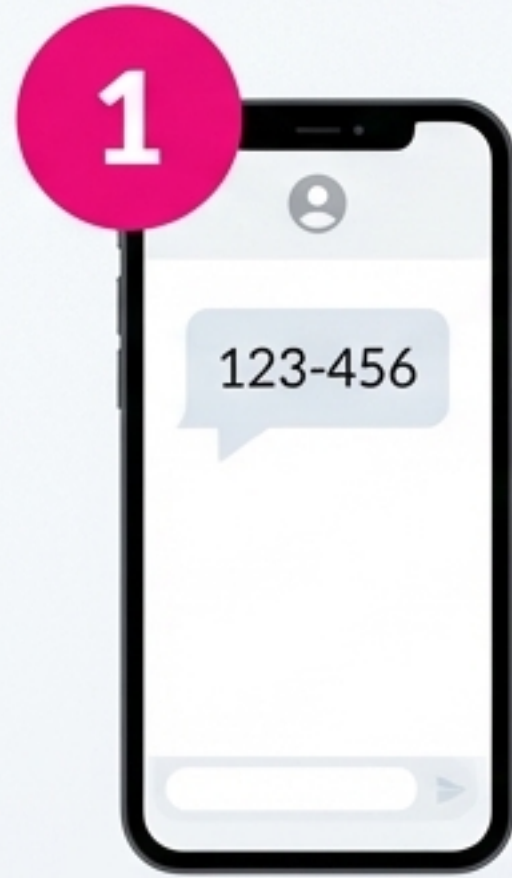
Das Architektur-Prinzip: Ein Passkey, unzählige Services



Zentrale Verwaltung.
Passkeys gehören zur Mobile ID Domain,
nicht zur Relying Party.

Der Benutzer registriert sich genau einmal auf mobileid.ch und nutzt denselben Passkey über OIDC bei beliebig vielen angebundenen Services.

Die Benutzersicht: Registrierung & Login



Verifizierung

Sicherer Start. Einmalige Verifizierung der Besitzverhältnisse via SMS OTP im MyMobileID Portal.



Erstellung

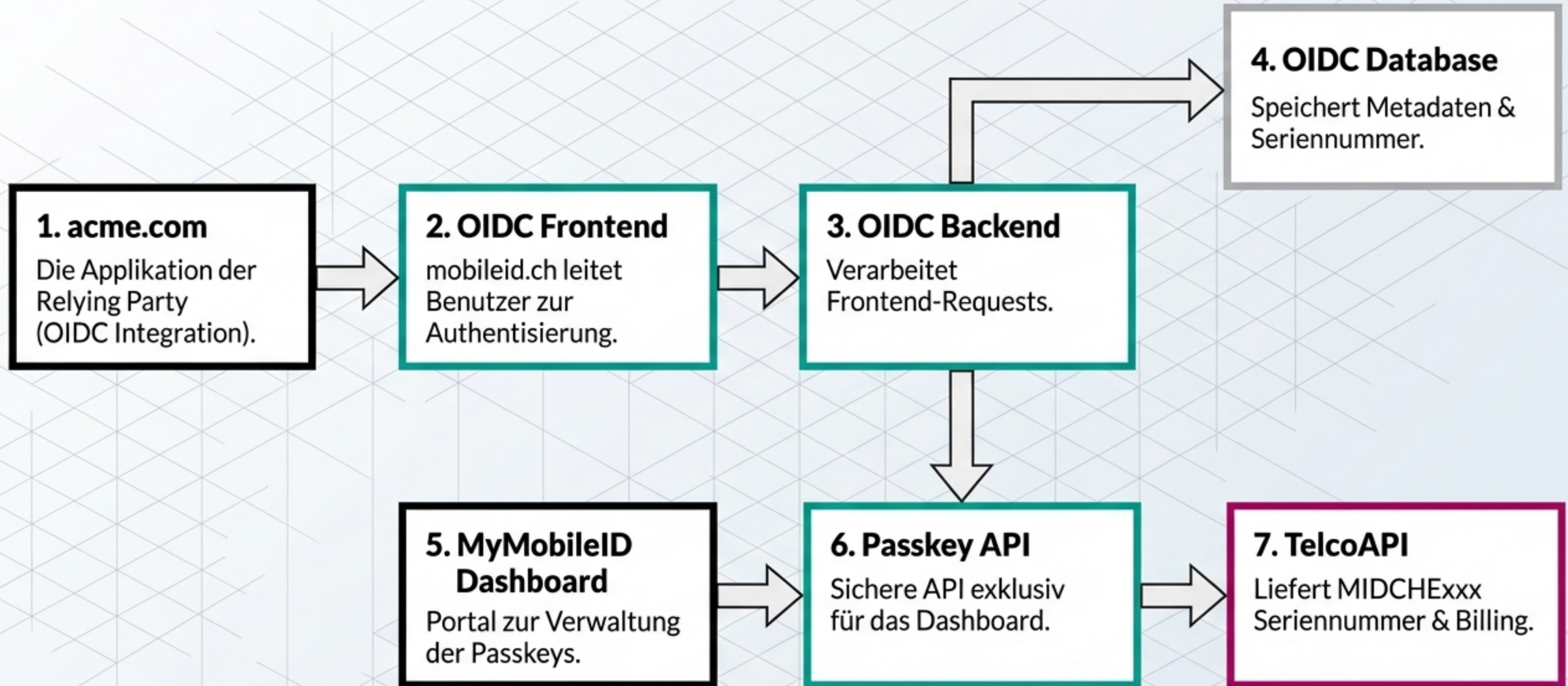
Passkey generieren. Das Gerät erstellt das asymmetrische Schlüsselpaar und bindet es an die Mobile ID Domain.



Nahtloser Login

Login in <3 Sekunden. Bei jeder Relying Party, die Mobile ID angebunden hat, erfolgt der Login rein biometrisch.

Solution Design Architecture Blueprint



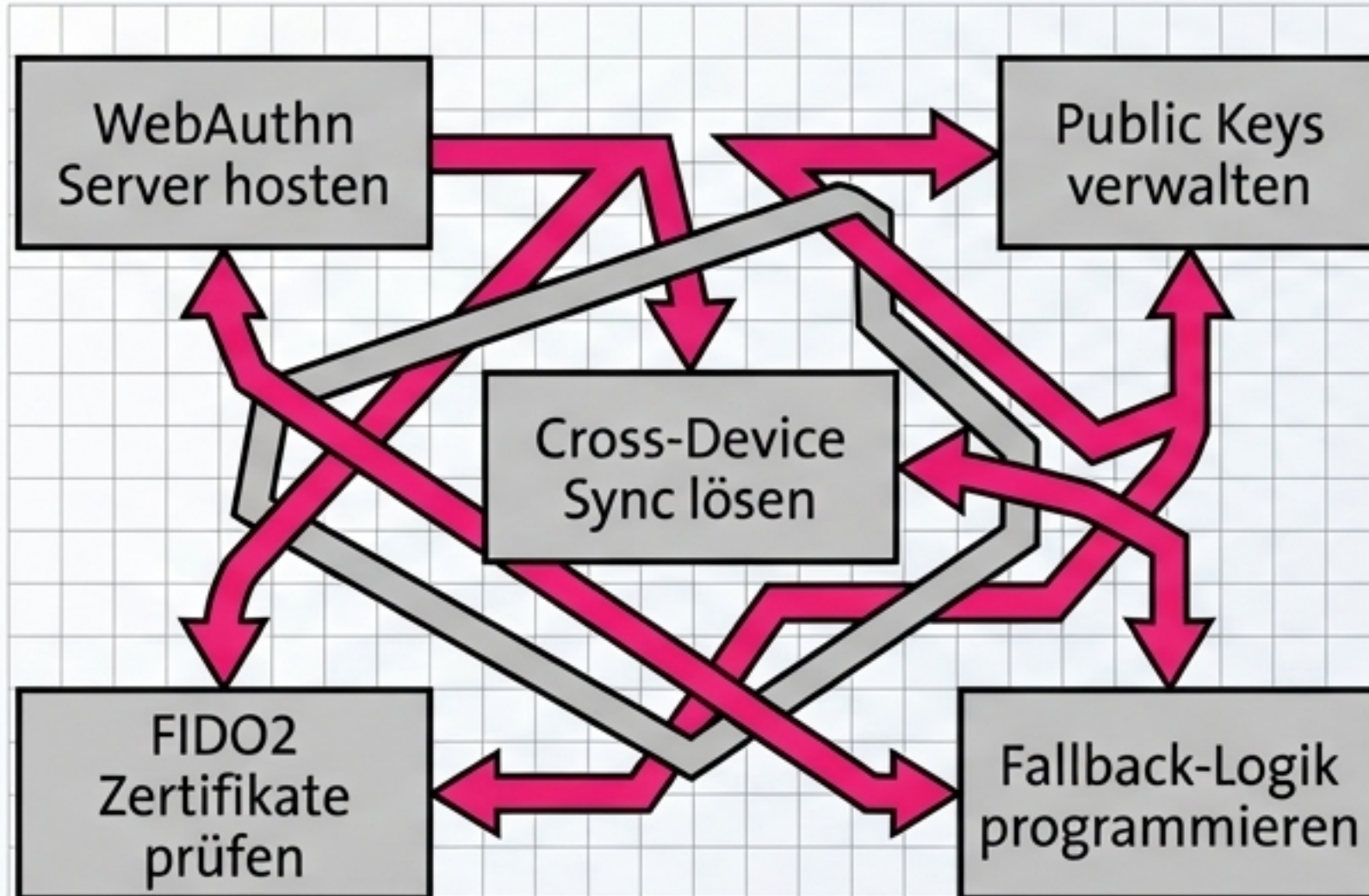
FIDO2 Authenticator-Typen im Vergleich

Typ	Phishing-Resistenz	Benutzerfreundlichkeit	AAL3 / FIPS Konform
Roaming (z.B. YubiKey)	Ja 	Mittel (Hardware nötig)	Ja (FIPS-zertifiziert)
Platform (Windows Hello, Mac TouchID)	Ja 	Sehr Hoch	Nein (Gerätegebunden, nicht FIPS)
Cloud-Synced (Apple/Google Passkeys)	Ja 	Höchste (Cross-Device)	Nein (Exportierbar via Cloud)
Device-Bound (Mobile ID streng)	Ja 	Hoch	Ja (Nicht-exportierbar)

Cloud-Synced Passkeys bieten die beste UX. Für strengste regulatorische Vorgaben (AAL3) können FIPS-zertifizierte Hardware-Token über denselben Standard integriert werden.

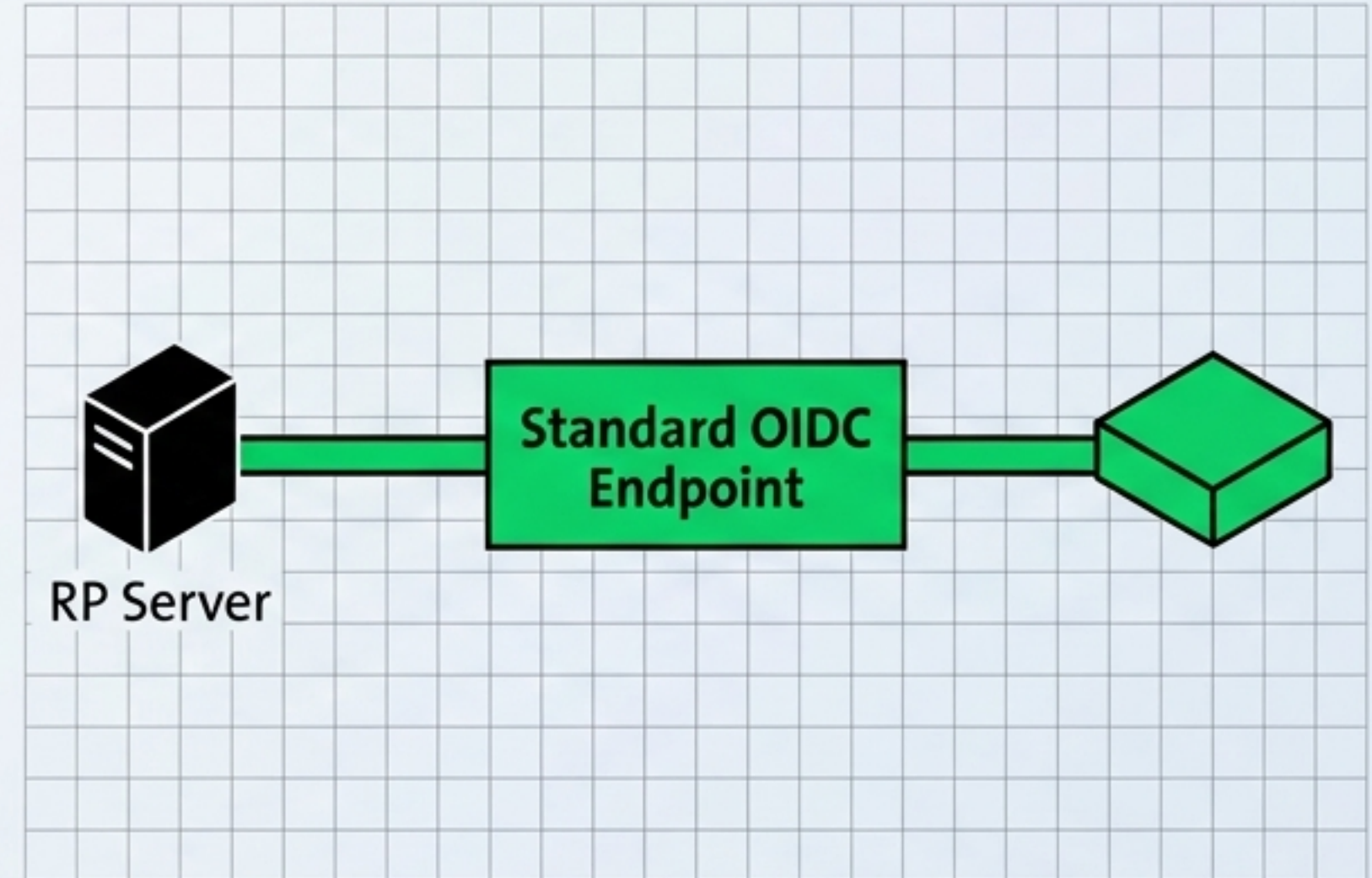
OIDC-Integration: Warum das Rad neu erfinden?

DIY WebAuthn



Eigene Implementierung: Hohe Wartungskosten, komplexes Lifecycle-Management.

Mobile ID OIDC



Mobile ID Integration: Die Komplexität der FIDO2-Standards wird vollständig abstrahiert. Kein eigenes Passkey-Backend erforderlich.

Authentisierungslevel steuern (ACR-Werte)

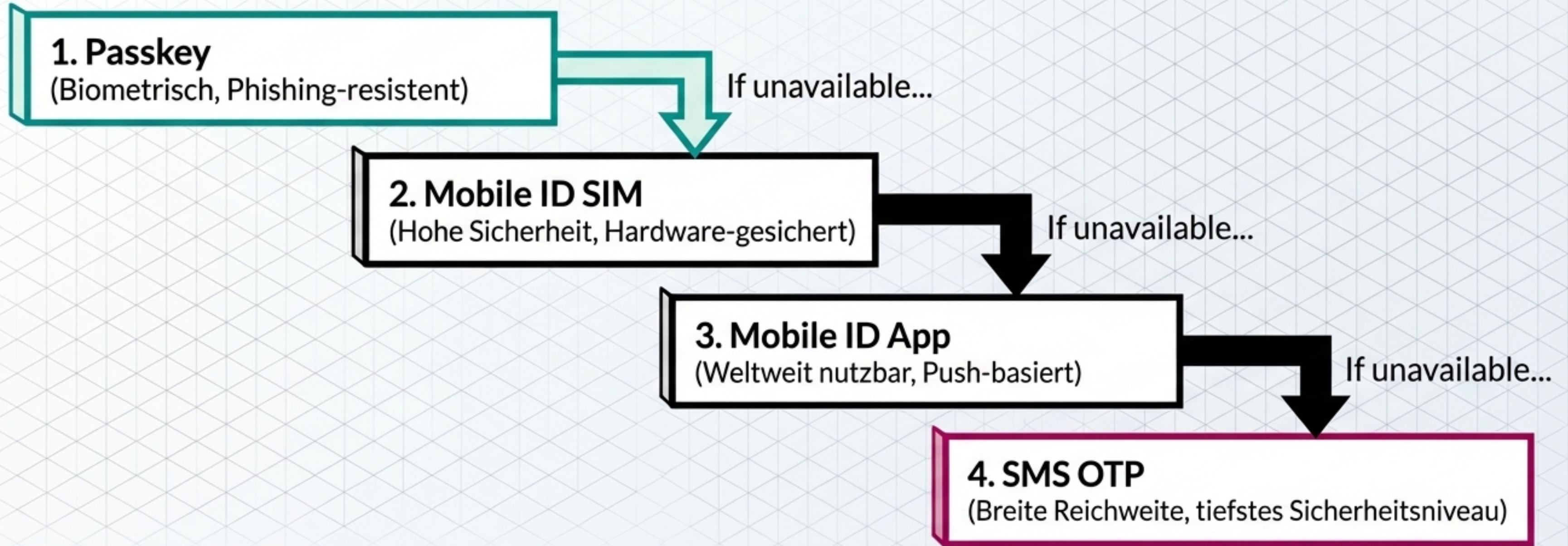
MID_AL2_ANY	Passkey-bevorzugt. Fallback durch User wählbar. Fokus: Maximale Benutzerfreundlichkeit (UX).
MID_AL4_ANY	Passkey-bevorzugt. Fallback erlaubt. Fokus: Hohe Sicherheit, Phishing-Risiko beim Fallback ist für den Use-Case akzeptabel.
MID_AL4_PASSKEY	Passkeys exklusiv. Fokus: Höchste Sicherheit (Phishing-resistent). Kein Fallback auf schwächere Methoden. <i>Dev Note: RP muss keyringId im login_hint mitsenden.</i>



Backward Compatibility: Ignoriert eine RP diese Parameter (**passkeys_enabled:false**), bleibt das Laufzeitverhalten identisch zum bisherigen Live-Release.

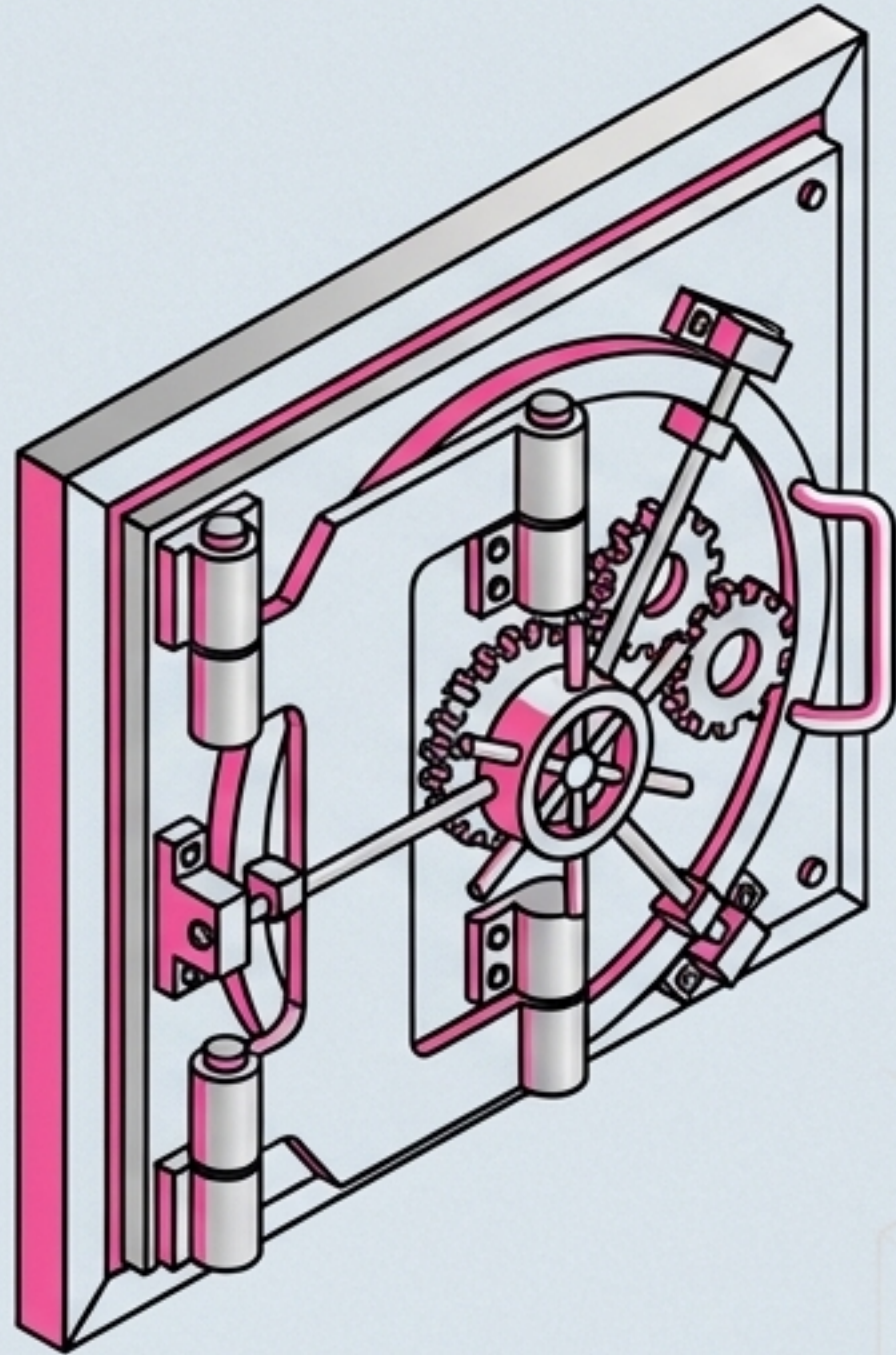
Intelligente Fallback-Logik (_any ACRs)

Wenn Parameter **passkeys_enabled = true** gesetzt ist:



Ein Benutzer kann mehrere Methoden parallel besitzen.
Dies garantiert eine reibungslose Account-Recovery und Migration.

Compliance auf Enterprise-Niveau: NIST AAL3



- ✓ Zwei unterschiedliche Authentisierungsfaktoren.
- ✓ Asymmetrisches kryptografisches Protokoll (Public-Key).
- ✓ Phishing-resistentes Verfahren (FIDO2 Standard).
- ✓ Nicht-exportierbarer privater Schlüssel.
- ✓ FIPS 140-2 Level 2 (oder höher) validiertes Hardware-Modul.

Während Mobile ID SIM und App den AAL2-Standard souverän erfüllen, ermöglicht der Passkey-Support mit FIPS-zertifizierten Hardware-Authenticatoren nun den Sprung auf das höchste NIST AAL3 Niveau.

Schweizer Datenhaltung & Digitale Souveränität



Keine Big-Tech-Abhängigkeit

Vollständige Infrastruktur und Datenhaltung in der Schweiz. Konform mit strengen Schweizer Datenschutzgesetzen.



Continuous Adaptive Trust (CAT)

Transaktionsbezogene Meldungen und kontinuierliche Überprüfung während bestehender Sitzungen.

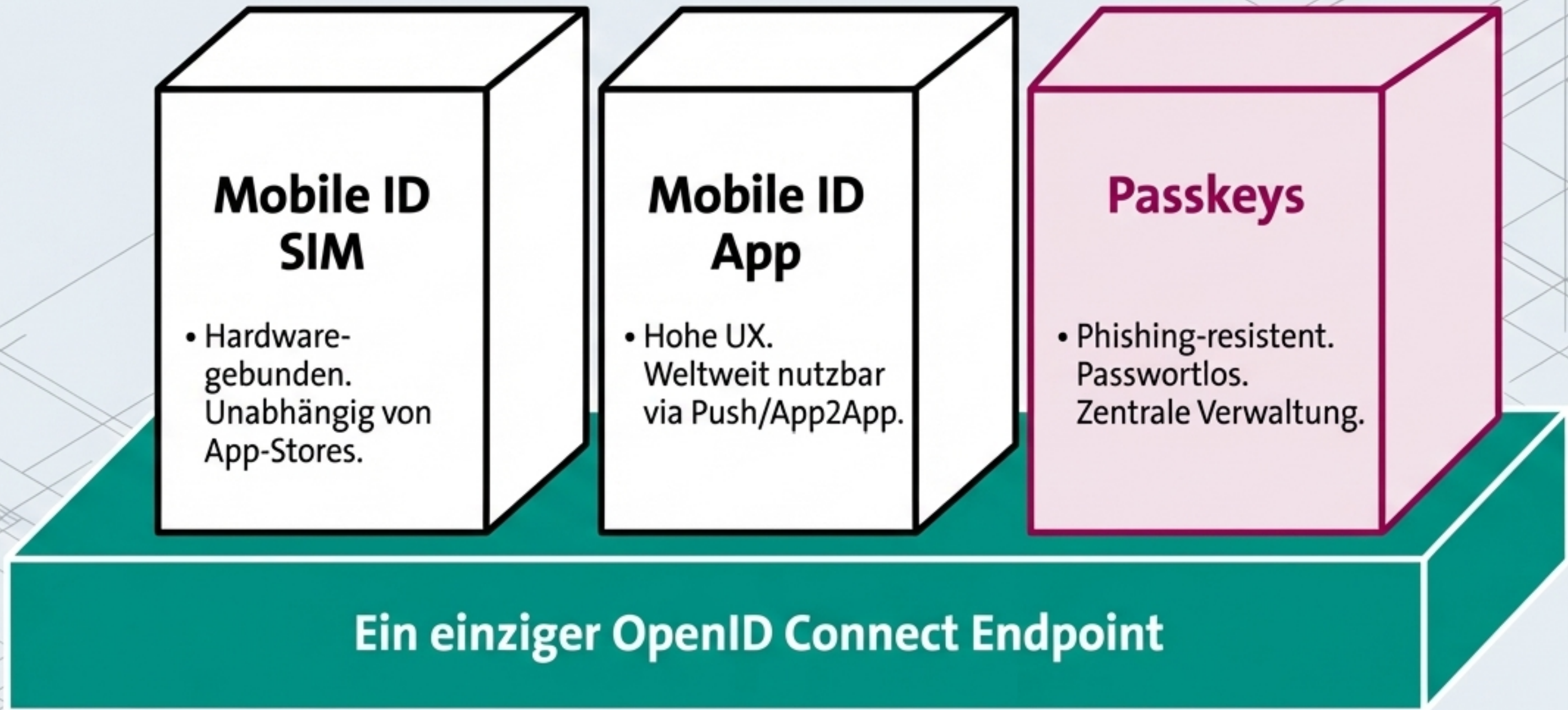


Geofencing

Zuverlässige, landesbezogene Standortdaten als Grundlage für granulare Zugriffskontrollen.

Das Mobile ID Ökosystem: Alles aus einer Hand

Passkeys erweitern Mobile ID nicht als Fremdsystem, sondern vervollständigen es. RPs erhalten das komplette Spektrum an Authentisierungsmethoden durch eine einzige Integration.



Die Benefits für Relying Parties auf einen Blick



UX & Conversion

- Keine Passwörter, keine vergessenen Logins.
- Authentisierung in unter 3 Sekunden.
- Einmal registrieren, überall nutzen.



Security & Compliance

- Resistent gegen Phishing, Credential Stuffing und MFA-Fatigue.
- Unterstützt NIST AAL3 Anforderungen.
- Schweizer Datenhaltung.



Developer Savings

- Keine Entwicklung eines eigenen WebAuthn/FIDO2-Backends.
- Einfache Integration in bestehende Systeme (Entra ID, Cognito) via OIDC.
- Out-of-the-box Fallback-Logik.

Bereit für die passwortlose Zukunft?

```
> systemctl start passkey-integration
```

[Developer Hub]
Technische Dokumentation
und OIDC Parameter
(docs.mobileid.ch)

[MyMobileID Portal]
Passkeys live testen
(mobileid.ch/test)

[Kontakt]
Sprechen Sie mit unserem
Integrations-Team